shiftflow セキュリティシート

使用するサービス・預ける情報・漏洩対策の一覧(2026年11月時点。詳しくはリポジトリの SECURITY.md)

1. 使用するサービスと預ける情報・漏洩対策

サービス	使い道	預ける情報	漏洩対策
Supabase	データベース・ログイン・サーバーの処理・アプリ内のカレンダー(写真の保管を含む)	社員番号・氏名・区所・PIN・勤務の行路番号とメモ・交番の休みの並び・マスタ・アプリ内のカレンダーの予定と写真・カレンダーID(Google連携の人のみ)	本人のデータのみ読み書きできる(RLS)。PINは暗号化(ハッシュ)した値のみ保存。勤務の内容・カレンダーの予定と写真・カレンダーIDは管理者にも見えない。カレンダーの共有をした相手にのみ、本人が選んだ範囲の勤務(メモは時間のみ)を見せる(範囲はサーバーで確認)
Google カレンダー(連携・任意。Google Cloud のサービスアカウント)	他のカレンダーアプリとの同期や家族との共有を希望する人のみ、勤務の予定を登録する	勤務の予定(行路番号・時刻・泊地)	初期設定は連携なし(Googleに何も送らない)。連携する人も、本人が共有したカレンダーにのみ登録する。メインのカレンダーには登録できない。共有はいつでも停止できる
Google ログイン(簡単設定・連携する人のみ)	カレンダーを自動で作成する	保存しない	権限はアプリが作成したカレンダーのみ(calendar.app.created)。許可は使用後すぐに取り消す
GitHub Pages	画面(Webページ)の公開	なし(画面のプログラムのみ)	パスワード・キー等の秘密の値はリポジトリに記載しない
Claude(写真取込・任意)	勤務指定表の画像の読み取り	画像は本人の Claude アカウントへ送られる	shiftflow のサーバーには画像を送らない。取り込むのは本人の行路番号のみ
Discord	管理者への通知(お問い合わせ・ロック)	お問い合わせの内容	通知先の URL は秘密の値として管理する。90日で削除
Gmail・Google Apps Script	お問い合わせのメール返信	メールアドレス・内容・画像	専用アカウントで取り扱う。送信元は合言葉(秘密の値)で確認する。画像の位置情報は削除する。90日で削除
cron-job.org	データベースの停止を防ぐ(6時間毎)	なし	公開用のキーのみ使用する。個人情報は取り扱わない

2. 漏洩対策のチェックリスト

- ✓ ログイン: 社員番号(7桁)+PIN(4桁)。5回失敗で15分ロック。PINを24時間に20回間違えると24時間ロックし、管理者に通知
- ✓ 新規登録: 共通パスワードを知っている人のみ。共通パスワードは暗号化(ハッシュ)した値のみ保存し、管理画面から変更できる
- ✓ 管理画面: 管理用パスワード(12文字以上)で入る。管理者にも PIN・勤務の内容・カレンダーの予定と写真・カレンダーIDは見えない
- ✓ 外部に出さない: 初期設定はアプリ内のカレンダーのみで使用し、勤務は Google に送らない。Google連携は、他のカレンダーとの同期を希望する人のみ
- ✓ 通信: 全て HTTPS(暗号化された通信)
- ✓ 必要最小限: 預かるのは勤務の入力・カレンダーの表示に必要な情報のみ。広告・分析には使用せず、第三者に渡さない
- ✓ カレンダーの共有: 本人がお誘いを送るか受けた相手にのみ、選んだ範囲の勤務を見せる(5人まで・いつでもやめられる)。社員番号から人を探すのはサーバー内のみで、相手が登録しているかは分からない。「夫婦」は招待した人のカレンダーを2人で使う(「自分だけ」のラベルの予定は作った人のみ)
- ✓ 秘密の値: キー・パスワードは Supabase・GitHub の秘密の設定にのみ置く。漏洩の疑いがあれば作り直す

3. 保存期間(自動で削除)

情報	削除のタイミング
勤務の記録	毎日、13か月前の月の1日より前の分を削除(Google カレンダーに登録した予定は消えない)
アプリ内のカレンダーの予定・スタンプ	毎日、12か月前の月の1日より前の分を削除
予定に付けた写真	予定の終了から1か月で削除(「画像」に置いた画像は1人10枚まで[夫婦の共有は20枚]。本人が削除する)
ログイン失敗の記録	30日以上更新が無い時に削除
お問い合わせ(内容・メール・画像・通知)	最後のやり取りから90日で削除
古いマスタ(前のダイヤ)	次のマスタの切替日が13か月前の月の1日以前になったら削除
利用者	退職・異動等で使用しなくなった時に、管理者が管理画面で削除(カレンダーの予定・写真も同時に削除される)。夫婦の共有中は、相手が作った物を相手のカレンダーに戻してから消す

4. 事故発生時の対応

①止める: 漏洩したキー・パスワード・通知先の URL を無効にして作り直す
②範囲を調べる: ログインの記録・サーバーのログ・変更の履歴から、何が見えた可能性があるかを調べる
③知らせる: 影響のある利用者に、分かっていること・直したこと・お願い(PINの変更等)を伝える
④直して残す: 原因を直し、再発防止策を記録する